The weakest link : Account Recovery

What happen when users

- forget their login and/or password
- lose their devices
  with its stored TOTP secrets and/or passkeys

Account recovery can be implemented:

- using an email address (that can also be compromised)
- using another device (that can also be lost)
- using a seed passphrase to derive a private key directly (that can also be lost)

- Account recovery hijacking is often another attack vector

Another weak link : The Session

A user authenticates once, then accesses resources across many subsequent requests **but how does the system remember that authentication?**

➡ This is the concept of **session** that can be achieved using several mechanisms such as session keys, session cookies, bearer tokens, refresh tokens and so on

◉ Session hijaking is yet another attack vector
(more about that topic towards the end of semester)